VULNERA

Gestão de análises de segurança

Relatório DAST — demonstração

http://localhost:8086/qa-QA-20261015-UI-mv9hhdmd

EMPRESA
localhost

APLICAÇÃO
Resultado simulado — sem acesso ao alvo

GERADO EM
15/10/2026 às 09:00

Demonstração com achados fictícios, sem executar o ZAP ou acessar o alvo. Solicitado por Vulnera Admin · Duração: 3s.

Documento confidencial — uso restrito às partes envolvidas na análise.

Sumário executivo

Esta demonstração gerou 15 alertas fictícios. O alvo http://localhost:8086/qa-QA-20261015-UI-mv9hhdmd não foi acessado. Cada um está detalhado, por ordem de severidade, na seção seguinte deste documento.

15	5	5	4
Total de achados	Alto	Médio	Baixo

Distribuição por risco

Findings por severidade

Alta 1. SQL Injection

Confiança: High · CWE-89 · WASC-19

URL
http://localhost:8086/search

PARÂMETRO
q

DESCRIÇÃO
SQL injection pode permitir ao atacante ler/alterar dados do banco.

SOLUÇÃO
Use queries parametrizadas/prepared statements.

Alta 2. Remote OS Command Injection

Confiança: Medium · CWE-78 · WASC-31

URL
http://localhost:8086/api/ping

PARÂMETRO
host

DESCRIÇÃO
Permite executar comandos arbitrários no servidor.

SOLUÇÃO
Nunca repasse input do usuário pra shell; use APIs seguras.

Alta 3. SQL Injection

Confiança: High · CWE-89 · WASC-19

URL
http://localhost:8086/login

PARÂMETRO
user

DESCRIÇÃO
SQL injection pode permitir ao atacante ler/alterar dados do banco.

SOLUÇÃO
Use queries parametrizadas/prepared statements.

Alta 4. Cross Site Scripting (Reflected)

Confiança: High · CWE-79 · WASC-8

URL
http://localhost:8086/comment

PARÂMETRO
text

DESCRIÇÃO
Entrada refletida sem sanitização permite injeção de script no navegador da vítima.

SOLUÇÃO
Codifique a saída conforme o contexto (HTML/JS/URL).

Alta 5. Cross Site Scripting (Reflected)

Confiança: High · CWE-79 · WASC-8

URL
http://localhost:8086/search

PARÂMETRO
q

DESCRIÇÃO
Entrada refletida sem sanitização permite injeção de script no navegador da vítima.

SOLUÇÃO
Codifique a saída conforme o contexto (HTML/JS/URL).

Média 6. Content Security Policy (CSP) Header Not Set

Confiança: High · CWE-693 · WASC-15

URL
http://localhost:8086/api

DESCRIÇÃO
Sem CSP, o navegador não tem uma camada extra de defesa contra XSS/injeção de dados.

SOLUÇÃO
Configure o header Content-Security-Policy.

Média 7. Content Security Policy (CSP) Header Not Set

Confiança: High · CWE-693 · WASC-15

URL
http://localhost:8086/

DESCRIÇÃO
Sem CSP, o navegador não tem uma camada extra de defesa contra XSS/injeção de dados.

SOLUÇÃO
Configure o header Content-Security-Policy.

Média 8. Content Security Policy (CSP) Header Not Set

Confiança: High · CWE-693 · WASC-15

URL
http://localhost:8086/login

DESCRIÇÃO
Sem CSP, o navegador não tem uma camada extra de defesa contra XSS/injeção de dados.

SOLUÇÃO
Configure o header Content-Security-Policy.

Média 9. Missing Anti-clickjacking Header

Confiança: Medium · CWE-1021 · WASC-15

URL
http://localhost:8086/login

DESCRIÇÃO
Sem X-Frame-Options/CSP frame-ancestors, a página pode ser embutida em iframe de terceiros (clickjacking).

SOLUÇÃO
Configure X-Frame-Options: DENY ou CSP frame-ancestors.

Média 10. Missing Anti-clickjacking Header

Confiança: Medium · CWE-1021 · WASC-15

URL
http://localhost:8086/

DESCRIÇÃO
Sem X-Frame-Options/CSP frame-ancestors, a página pode ser embutida em iframe de terceiros (clickjacking).

SOLUÇÃO
Configure X-Frame-Options: DENY ou CSP frame-ancestors.

Baixa 11. X-Content-Type-Options Header Missing

Confiança: Medium · CWE-693 · WASC-15

URL
http://localhost:8086/

DESCRIÇÃO
Sem nosniff, o navegador pode reinterpretar o tipo de conteúdo por heurística.

SOLUÇÃO
Configure X-Content-Type-Options: nosniff.

Baixa 12. X-Content-Type-Options Header Missing

Confiança: Medium · CWE-693 · WASC-15

URL
http://localhost:8086/api

DESCRIÇÃO
Sem nosniff, o navegador pode reinterpretar o tipo de conteúdo por heurística.

SOLUÇÃO
Configure X-Content-Type-Options: nosniff.

Baixa 13. Cookie No HttpOnly Flag

Confiança: High · CWE-1004 · WASC-13

URL
http://localhost:8086/

DESCRIÇÃO
Cookie sem HttpOnly pode ser lido via JavaScript — risco em caso de XSS.

SOLUÇÃO
Marque o cookie de sessão como HttpOnly.

Baixa 14. Cookie No HttpOnly Flag

Confiança: High · CWE-1004 · WASC-13

URL
http://localhost:8086/login

DESCRIÇÃO
Cookie sem HttpOnly pode ser lido via JavaScript — risco em caso de XSS.

SOLUÇÃO
Marque o cookie de sessão como HttpOnly.

Informativa 15. Timestamp Disclosure

Confiança: Medium · CWE-200 · WASC-13

URL
http://localhost:8086/api/status

DESCRIÇÃO
Um timestamp Unix foi identificado na resposta.

SOLUÇÃO
Avalie se a informação exposta é sensível ao contexto.

Apêndice

METODOLOGIA

Demonstração: os achados são fictícios, gerados pelo Vulnera sem executar o OWASP ZAP nem acessar o alvo. Este relatório serve para apresentar a interface e não comprova vulnerabilidades na aplicação informada.

VERSÃO DO ZAP

Não se aplica: o OWASP ZAP não foi executado nesta demonstração.

ESCOPO

Alvo informado para demonstração: http://localhost:8086/qa-QA-20261015-UI-mv9hhdmd. Nenhuma requisição foi enviada a ele.

TRIAGEM E GESTÃO DE RESULTADOS

Os achados fictícios permitem apresentar a interface de triagem. Promoção para vulnerabilidades e comparação operacional ficam indisponíveis para execuções de demonstração.

LIMITAÇÕES CONHECIDAS

O ZAP não fornece vetor CVSS: o risco do alerta não substitui a avaliação humana. No perfil atual, o spider tradicional não executa JavaScript, portanto rotas de uma SPA que dependem dessa execução podem não ser descobertas. O perfil atual não cobre exploração ativa, envio de formulários ou uma auditoria completa da aplicação. Não há agendamento recorrente nem varredura de múltiplos alvos num único scan.